

LETRA DE TAREA Opción 2 — Sistema de Gestión Integrada para el RSI

Curso: Seguridad de la Información

Módulo: Práctica integradora

— Blue Team / Red Team

Equipos: 2 (Blue Team y Red Team)

Modalidad: Open source obligatorio

Versión: 1.0

Fecha: [DD/MM/AAAA]

0. Resumen de la tarea

Diseñar e implementar un **sistema de gestión para el Responsable de Seguridad de la Información (RSI)** de una organización, que permita:

- Modelar el **organigrama** (áreas, divisiones, departamentos, sectores) y asociar responsabilidades a trabajadores.
- Construir un **mapa/matriz de la organización** y sus responsabilidades de seguridad.
- Gestionar **vulnerabilidades, incidentes y riesgos**.
- Crear **políticas, procesos, procedimientos, planes de acción y planes anuales**.
- Registrar **activos** y verlos por **área/división/departamento/sector**.
- **Exportar documentos** en los formatos/plantillas que exigen: **MCU 5.0, BCU (GSI), URCDP, ISO 27001 y COBIT**.
- Definir **indicadores, métricas y KPI**, con visualización (dashboard).

La herramienta debe ser **útil para el RSI** pensada para el **Marco de Ciberseguridad de Uruguay (MCU 5.0)** y los **Requerimientos Mínimos del BCU**.

Además, la solución debe poder configurar **autenticación con TOTP, Windows Hello, WebAuthn/U2F** y elegir algoritmos (Argon2 por ejemplo).

La tarea se desarrolla en dos partes: **Blue Team** (construcción) y **Red Team** (ataque).

0.1 Perfil MCU 5.0 objetivo: **AVANZADO**

El perfil de cumplimiento del **Marco de Ciberseguridad 5.0 (AGESIC)** exigido es el **perfil comunitario AVANZADO**. Esto implica:

- Justificar los controles del perfil **Avanzado** (no solo el mínimo).
- Completar y entregar los **Excel** de plantilla/mcu5/excel/:
 - 01-controles-mcu5-perfil-avanzado.xlsx — controles por función con evidencia y cómo se demuestra.
 - 02-registro-activos-mcu5.xlsx — inventario de activos.
 - 03-matriz-raci-mcu5.xlsx — responsabilidades (RACI) por proceso.
 - 04-bitacora-planilla.xlsx — bitácora de trabajo.
- Cada control declara **Sí/No/N.A.** y los N.A. llevan **justificación aceptada**.

0.2 Modelo de arquitectura obligatorio

Presentar la arquitectura con plantilla/plantilla-arquitectura-4más1.md y /0 plantilla/plantilla-arquitectura-C4.md, antes de la demo funcional en la auditoría.

0.3 Calendario del curso (obligatorio)

Hito	Fecha	Evento
Pre-entrega Blue Team	miércoles 7 de octubre de 2026	Entrega congelada + arranque de auditoría
Entrega / Defensa Blue Team	miércoles 14 de octubre de 2026	Auditoría formal por función
Pre-entrega Red Team	miércoles 28 de octubre de 2026	Informe Red Team preliminar
Entrega final Red Team	lunes 9 de noviembre de 2026	Informe Red Team final + presentación

1. Marco teórico

1.1 El rol del RSI

El **Responsable de Seguridad de la Información (RSI)** promueve, coordina y controla el SGSI. Necesita una vista de **360°** de la organización: quién responde por cada activo, qué procesos la soportan y cómo se gestionan riesgos, incidentes, vulnerabilidades y cumplimiento.

1.2 Organigrama y mapa de responsabilidades (RACI)

- **RACI (Responsible, Accountable, Consulted, Informed)** aplicado a procesos de seguridad.

- El **organigrama** y el **mapa de procesos** permiten:
 - Asignar **dueños de activos**.
 - Definir **canales de escalamiento** de incidentes.
 - Identificar **áreas críticas** para BIA (Business Impact Analysis).

1.3 Gestión de riesgos, vulnerabilidades e incidentes

- **Riesgo**: probabilidad × impacto (ISO 31000). Tratamiento: M/T/R/A.
- **Vulnerabilidad**: vulnerabilidad técnica/organizativa; entrada al inventario (CVSS).
- **Incidente**: evento que compromete CIA o viola política; ciclo detect→contain→eradicate→recover→lessons (ISO 27035).

1.4 Políticas, procesos y procedimientos

Jerarquía documental: 1. **Política** (qué y por qué) — aprobada por Dirección. 2. **Proceso** (flujo quién-qué) — dueño de proceso. 3. **Procedimiento** (cómo, paso a paso) — operativo. 4. **Plan** (acciones con fechas, planes anuales).

1.5 Cumplimiento y exportaciones

Marco	Documentos que el sistema debe poder exportar
MCU 5.0	Reporte por funciones (GV/ID/PR/DE/RS/RC), perfil comunitario (Básico/Estándar/Avanzado), evidencias de madurez.
BCU (GSI)	Informe de cumplimiento de requerimientos mínimos; reporte trimestral de madurez MCU (Tipo dato 957).
URCDP (Ley 18.331)	Registro de bases de datos personales, informe de medidas de seguridad, notificación de brechas.
ISO 27001	SoA (declaración de aplicabilidad), inventario de activos, plan de tratamiento, política, informe de auditoría interna.
COBIT 2019	Alineación de procesos con EDM/APO/BAI/DSS/MEA, indicadores de madurez de procesos.

1.6 Indicadores y KPIs

- **KRI** (riesgo): número de hallazgos críticos abiertos.

- **KPI** (desempeño): % de vulnerabilidades remediadas dentro de SLA; MTDD; MTTR; cobertura de capacitación.
- Visualización con **dashboard** para la Alta Dirección.

2. Glosario (específico de la tarea)

Término	Definición
RSI	Responsable de Seguridad de la Información.
Organigrama	Representación jerárquica de la organización (áreas/divisiones/deptos/sectores).
RACI	Matriz de responsabilidades (Responsable/Cuenta/Consultado/Informado).
BIA	Análisis de impacto en el negocio.
Activo	Bien o recurso con valor a proteger.
Riesgo	Efecto de la incertidumbre sobre los objetivos (ISO 31000).
Vulnerabilidad	Superficie explotable.
Incidente	Evento que compromete la CIA o viola una política.
Política/Proceso/Procedimiento	Jerarquía documental del SGSI.
Plan de acción	Conjunto de tareas con responsables y fechas.
Plan anual	Programa de seguridad del año (capacitación, auditorías, pruebas).
SoA	Declaración de aplicabilidad (ISO 27001).
Perfil comunitario MCU 5.0	Básico/Estándar/Avanzado de controles.
MVC/CRUD	Patrón para altas/bajas/listados de los elementos del sistema.

3. Requerimientos funcionales (RF)

ID	Requerimiento
RF-01	CRUD de organigrama : áreas→divisiones→departamentos→sectores, con responsable de cada unidad.
RF-02	Matriz RACI por proceso de seguridad

ID	Requerimiento
	(dueño del proceso, responsables, consultados, informados).
RF-03	CRUD de trabajadores con cargo, unidad y responsabilidades de seguridad asignadas.
RF-04	Mapa/matriz de la organización: vista jerárquica + vista RACI por proceso.
RF-05	CRUD de activos con tipo (HW/SW/dato/servicio), dueño (unidad y persona), clasificación, criticidad; filtro por área/división/departamento/sector.
RF-06	CRUD de vulnerabilidades (CVSS, estado, plan de remediación, SLA, responsable).
RF-07	CRUD y ciclo de vida de incidentes (detección→contención→erradicación→recuperación→lecciones).
RF-08	CRUD de riesgos con metodología ISO 31000 (prob×impacto, tratamiento M/T/R/A, riesgo residual, aceptación).
RF-09	CRUD de políticas, procesos, procedimientos con versión, estado (borrador/aprobada), responsable y fecha de revisión.
RF-10	CRUD de planes de acción y planes anuales con hitos, responsables y estado.
RF-11	Exportación de documentos en el formato de: MCU 5.0 (reporte por función + perfil), BCU (requerimientos mínimos + reporte trimestral madurez), URCDP (registro de BD personales + notificación brechas), ISO 27001 (SoA, plan de tratamiento, activos), COBIT (madurez e indicadores).
RF-12	Indicadores y KPI configurables con fórmulas y metas; histórico.
RF-13	Dashboard visual (Grafana o front propio) con KPIs para Alta Dirección.
RF-14	Autenticación: TOTP, WebAuthn/U2F,

ID	Requerimiento
	Windows Hello y selección de algoritmo (Argon2/bcrypt).
RF-15	Roles y permisos (Administrador, RSI, dueño de unidad, lector).
RF-16	Trazabilidad/auditoría de cambios (quién modificó qué y cuándo).
RF-17	Búsqueda global y filtros (por unidad, estado, severidad).
RF-18	Importación/exportación de datos (CSV/JSON) y backup/restore de la base.
RF-19	Registro de lecciones aprendidas vinculadas a incidentes.

4. Requerimientos no funcionales (RNF)

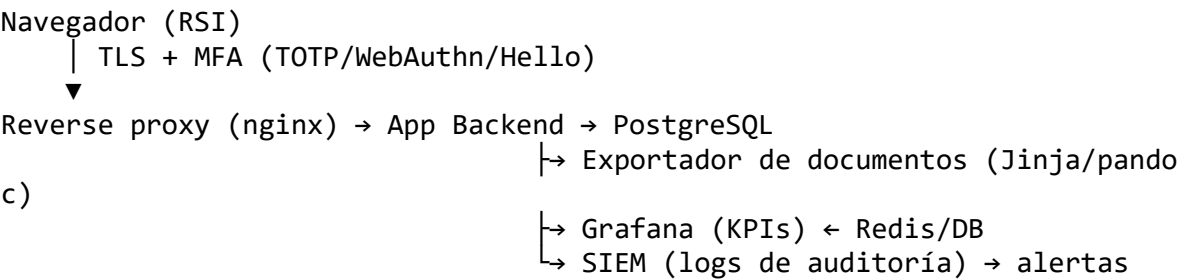
ID	Requerimiento
RNF-01	Disponible para el RSI desde navegador moderno (web app deployable en contenedor).
RNF-02	Rendimiento: listados con 50k registros < 3 s.
RNF-03	Disponibilidad 99%; backup automático diario con restauración probada.
RNF-04	Seguridad: TLS 1.2+, MFA obligatorio para roles administrativos, passwords con Argon2/bcrypt, mínimo privilegio por rol.
RNF-05	Trazabilidad completa de cambios ($\geq$ 1 año de retención).
RNF-06	Ubicación y resguardo de datos personales: cofre cifrado; registro para URCDP.
RNF-07	Open source en todo el stack (BD, app, SIEM, dashboard).
RNF-08	Usabilidad para no técnicos (RSI/Jefes de área).
RNF-09	Escalabilidad a 500 usuarios concurrentes.
RNF-10	Documentación de despliegue/operación y respaldo en repositorio GIT.

5. Arquitectura sugerida

Obligatorio: documentar la arquitectura con plantilla/plantilla-arquitectura-4más1.md (vistas 4+1) y/o plantilla/plantilla-arquitectura-C4.md antes de la demo funcional.

Capa	Tecnología open source sugerida	Rol
Frontend	React/Vue o Django/Flask templates; Grafana para dashboards	UI del RSI
Backend	Django, Flask, Node (Express), Laravel o similar	API REST y lógica
BD	PostgreSQL + Redis (cache)	Persistencia
Autorización	Keycloak (OIDC/SAML) o Auth propio + passkeys (WebAuthn) + TOTP	SSO/MFA/Algoritmos
SIEM/logs	Wazuh o ELK (independiente del RSI)	Trazas y auditoría
Exportación	Generador de plantillas (Pandoc / python-docx / Jinja)	SoA, MCU, BCU, URCDP, COBIT
Dashboard	Grafana + Metabase (opcional)	KPIs
CI/CD (opcional)	GitLab CE / Gitea + acciones	Mantenibilidad

Flujo



6. Parte 1 — Blue Team

6.1 Entregables

#	Entregable	Documento	Fase
---	------------	-----------	------

#	Entregable	Documento	Fase
1	Arquitectura y diseño de datos (modelo ER)	docs/00-arquitectura.md	Diseño
2	Política de seguridad	01-politica-seguridad	Inicio
3	Inventario/activos (del sistema y modelo)	02-registro-activos	Diseño
4	Análisis de riesgos	03-analisis-riesgos	Diseño
5	Gestión de accesos (TOTP/WebAuthn/Hello/Argon)	09-gestion-accesos	Implementación
6	Monitoreo/logs/SIEM	07-monitoreo-logs	Implementación
7	Vulnerabilidades	10-gestion-vulnerabilidades	Pre-entrega
8	Continuidad	06-plan-continuidad	Implementación
9	Incidentes	04-gestion-incidentes	Validación
10	SoA + brecha MCU	11-soa-plan-tratamiento	Cierre
11	Notificaciones (URCDP/BCU)	12-notificacion-incidentes	Cierre
12	Repositorio + tag	—	Entrega
13	Evidencias (demo ≤ 5 min video)	docs/evidencias/	Entrega
14	Informe Blue Team	docs/28-informe-blue-team.md	Entrega

Obligatorio demostrar: exportar al menos 3 documentos (MCU 5.0 perfil + SoA ISO 27001 + reporte BCU) con datos reales cargados (20+ activos, 10+ riesgos, 5+ incidentes, 5+ vulnerabilidades, 5 políticas, 5 procedimientos, 3 planes).

6.2 Hitos

Hito	Fecha	Ítem
H1	Lunes 21/09/2026	Modelo de datos + arquitectura aprobados
H2	Lunes 28/09/2026	CRUDs completos +

Hito	Fecha	Ítem
H3	Viernes 02/10/2026	organigrama Exportadores + dashboard + MFA
H4	Miércoles 07/10/2026 (pre-entrega)	Entrega congelada (git tag v1.0)
H5	Miércoles 14/10/2026 (defensa)	Auditoría formal

6.3 KPIs

- % de cumplimiento MCU 5.0 por función (auto-reporte del propio sistema).
- % de vulnerabilidades remediadas en SLA.
- MTTR de incidentes simulados.
- Precisión del inventario (activos con dueño asignado = 100%).
- Tiempo medio de generación de exportaciones (< 60 s).

6.4 Bitácora de trabajo (obligatoria)

Cada equipo debe llevar una **bitácora diaria** del trabajo:

- Plantilla: plantilla/isaca/99-bitacora-trabajo.md (+ Excel plantilla/mcu5/excel/04-bitacora-planilla.xlsx).
- Reglas: registro **diario**, cada miembro firma sus entradas, **no se omiten fallos**, hora UTC, evidencia real referenciada en docs/evidencias/.
- El Red Team registra cada intento de ataque (fase, herramienta, resultado).
- En la auditoría, cada control se valida contra las entradas de bitácora.

6.5 La auditoría (evaluación de la Parte 1)

La instancia de evaluación del Blue Team es una **auditoría de seguridad formal** donde la cátedra recorre las **funciones del MCU 5.0** (Gobernar, Identificar, Proteger, Detectar, Responder, Recuperar).

Proceso de la auditoría (orden obligatorio de presentación):

Paso	Qué se presenta	Tiempo sugerido
1	Demo funcional del sistema arrancando + diagrama de arquitectura (4+1 y C4) mostrando el sistema en vivo	10 min
2	Gobernar (política, organigrama, RACI,	10 min

Paso	Qué se presenta	Tiempo sugerido
	planes)	
3	Identificar (activos, riesgos, vulnerabilidades, mapa URCDP)	10 min
4	Proteger (accesos/MFA, cifrado, backups)	10 min
5	Detectar (SIEM/logs, monitoreo de cambios)	10 min
6	Responder (incidentes, notificaciones BCU/URCDP)	10 min
7	Recuperar (BCP, restauración)	5 min
8	Cierre: resultados de exportación (MCU/BCU/ISO) + preguntas	10 min

Cómo se evalúa cada control: para cada control del Excel 01-controles-mcu5-perfil-avanzado el equipo presenta **evidencia, cómo se demuestra** y la **aplicabilidad (Sí/No/N.A.) justificada**. El auditor puede pedir la demostración en vivo de cualquier control declarado.

Obligatorio en la auditoría: que el exportador genere en vivo los documentos de **MCU 5.0 (perfil Avanzado), BCU (GSI), URCDP, ISO 27001 (SoA) y COBIT** usando los datos cargados.

7. Parte 2 — Red Team

7.1 Reglas de compromiso

- Solo entorno de laboratorio del curso; no exfiltrar datos reales; no destruir datos sin acuerdo.
- El Red Team evaluará la solución sin acceso backend (modo “caja negra” inicial, luego “caja de cristal” para código en GIT).
- **Ventana activa:** del **28 de octubre al 9 de noviembre de 2026** (pre-entrega 28/10; entrega final 09/11).
- El Red Team mantiene **bitácora diaria de ataques**.
- **Pre-entrega (28/10):** informe preliminar con $\geq 70\%$ de hallazgos.

- **Entrega final (09/11):** informe completo según plantilla/informe-red-team.md + presentación ejecutiva.

7.2 Objetivos Red Team

ID	Objetivo
RT-01	Romper la autenticación (bypass MFA, fuerza bruta, phishing TOTP, null session).
RT-02	Abusar de rol/permisos (escalación de privilegios, IDOR sobre unidades).
RT-03	Inyecciones (SQL, XML, template SSTI) en módulos y exportadores (posible RCE vía plantillas).
RT-04	XSS persistente en campos de políticas/procedimientos (afecta al RSI).
RT-05	Manipular KPIs/dashboard (fake data para ocultar riesgo).
RT-06	Modificar/alterar exportaciones (tampering de SoA para ocultar incumplimiento).
RT-07	Envenenamiento de logs (log injection) para eludir auditoría.
RT-08	Secuestro de sesión (cookies sin flags, token en URL).
RT-09	Abuso de la API de exportación para enumerar datos (activado 01).
RT-10	Exposición de datos personales (URCDP) por fail-open en accesos.
RT-11	OSINT del repositorio (secretos commiteados).
RT-12	Denegación de servicio acotado en el exportador (generación pesada).

7.3 Herramientas Red Team (open source)

OWASP ZAP, Burp Community, nmap, sqlmap (autorizado), ffuf, nuclei, nikto, hashcat/John, Hydra, impacket (si aplica), curl/jq, semgrep, gitleaks.

7.4 Entregables Red Team

#	Entregable
1	Informe de evaluación técnica (plantilla

#	Entregable
	informe-red-team.md)
2	Inventario de hallazgos (CVSS + repro)
3	Mapeo MITRE ATT&CK
4	Registro de incidentes por plantilla
5	Informe de cumplimiento (qué afirmaciones del RSI se contradicen)
6	Presentación ejecutiva (10 min)
7	Bitácora Red Team diaria

7.5 Presentación del Red Team (entrega final 09/11)

Paso	Contenido
1	Resumen ejecutivo de hallazgos por severidad
2	Demo del top 3 de hallazgos críticos (repro)
3	Evaluación de eficacia de controles por función MCU
4	Respuesta del Blue Team a cada hallazgo
5	Entrega informe final (plantilla/informe-red-team.md) + bitácora

8. Matriz de documentación

8.1 Blue Team (14/09 al 07/10/2026)

Plantilla	Cuándo	Evidencia para completarla
01-politica-seguridad	1ª semana-30/09	Diseño + políticas del sistema
02-registro-activos	1ª semana y 06/10	Datos cargados + infraestructura
03-analisis-riesgos	18/09 y 06/10	Riesgos del sistema y de la org modelo
09-gestion-accesos	23-30/09	MFA y roles implementados
07-monitoreo-logs	28/09-01/10	Logs de auditoría y SIEM
10-gestion-	01-05/10	Escaneos + cargas de

Plantilla	Cuándo	Evidencia para completarla
vulnerabilidades		registro
Excel 01-controles-mcu5-perfil-avanzado	Semanal	Evidencias + cómo se demuestra por control
Excel 02-registro-activos-mcu5	1ª semana	Activos reales
Excel 03-matriz-raci-mcu5	23/09	RACI por proceso
Excel 04-bitacora-planilla	Diario	Entradas firmadas
Arquitectura 4+1 y C4	18/09	Diagramas completos

8.2 Entrega a Red Team

Cómo: git tag v1.0, docs/ congelada, hash SHA-256. **Cuándo:** pre-entrega 07/10/2026.

8.3 Red Team y cierre (28/10 al 09/11/2026)

Igual esquema que Tarea 1: cada hallazgo → plantilla 04/10; informe final según plantilla/informe-red-team.md (pre-entrega 28/10, entrega final 09/11); bitácora diaria; foro de lecciones; actualización post-evaluación.

9. Criterios de evaluación

Criterio	Peso
RF implementados y demostrables	30%
Calidad de plantillas y mapeo normativo (+ Excel MCU Avanzado)	20%
Exportadores correctos (MCU/BCU/ISO/COBIT/URCDP demostrados en vivo)	15%
Dashboard y KPIs	5%
Auditoría por función MCU	15%
Desempeño Red Team	12%
Presentación + bitácora	3%

10. Anexos

- Anexo A — Modelo de datos de referencia (mindmap RSI).
- Anexo B — Datos de prueba mínimos (organización modelo de 30 personas / 4 áreas).

- Anexo C — Formatos oficiales de exportación (MCU 5.0, GSI BCU, URCDP, ISO, COBIT).
- Anexo D — Plantillas de arquitectura 4+1 y C4 (plantilla/).
- Anexo E — Excel de controles/activos/RACI/bitácora (plantilla/mcu5/excel/).
- Anexo F — Plantilla de informe Red Team (plantilla/informe-red-team.md).